

HIPAA SECURITY AND BREACH NOTIFICATION STANDARDS

PROTECTED HEALTH INFORMATION (PHI) SECURITY RULES

Section 1: ADMINISTRATIVE SAFEGUARDS

All business associates and covered entities must perform a formal, documented security risk analysis annually. Mandatory training programs must be conducted for all staff handling Protected Health Information (PHI).

Section 2: TECHNICAL SAFEGUARDS & ACCESS CONTROLS

Access to electronic PHI (ePHI) must be limited to authorized personnel with unique user logins. Encryption must be implemented for ePHI both in transit (e.g., SSL/TLS) and at rest (e.g., AES-256) unless a documented alternative is implemented.

Section 3: BREACH NOTIFICATION RULE

Breaches of unsecured PHI affecting five hundred (500) or more individuals require immediate notification to the Department of Health and Human Services (HHS) and local media outlets within sixty (60) days of discovery. Smaller breaches must be logged and reported annually.